

- Rapport d'incident de l'ANSSI sur la DGFIP

« La compromission des SI de la DGFIP n'est pas la conséquence d'une attaque sophistiquée, mais de l'exploitation de faiblesses dans trois domaines »

ANSSI, rapport d'incident du 23 septembre 2026, p. 4

5 leçons pour une PME

Leçon 1

Pas d'appareil personnel sur les outils de l'entreprise

Des dizaines d'identifiants d'agents ont été volés,
« probablement » par des logiciels espions installés sur des
ordinateurs non administrés par la DGFIP.

- Pour une PME

On se connecte aux outils de l'entreprise depuis un poste
géré par l'entreprise.

Leçon 2

Un second facteur qui résiste au vol du mot de passe

Le code à usage unique envoyé par email a été jugé insuffisant. Il n'est « pas un choix raisonnable » si la messagerie s'ouvre avec un simple identifiant et un mot de passe.

● Pour une PME

Préférer une application d'authentification ou une clé physique, sur un autre appareil que celui de la connexion.

Leçon 3

Changer le mot de passe ne suffit pas

Le 24 juin, le mot de passe du compte utilisé a été réinitialisé : la session ouverte et l'exfiltration ont continué. Et un mot de passe changé sur un appareil infecté peut être volé à nouveau.

- Pour une PME

Couper les sessions ouvertes, vérifier l'activité du compte depuis la compromission, nettoyer l'appareil.

Leçon 4

Repérer l'inhabituel



échangés entre le 22 et le 25 juin 2026 lors des connexions de l'attaquant, sans alerte. Connexions nocturnes, volumes anormaux, adresses IP malveillantes : aucun signal n'a été corrélé.

- Pour une PME

Savoir qui est alerté quand un compte télécharge beaucoup, la nuit, depuis une adresse inhabituelle.

Leçon 5

Vos partenaires sont une porte d'entrée

Le poste compromis d'un géomètre-expert, dans un cabinet privé, a permis de contourner la double authentification par messagerie et d'exfiltrer des données cadastrales.

- Pour une PME

Les accès de vos prestataires et partenaires méritent les mêmes exigences que les vôtres.

À retenir

- 1 Des postes gérés par l'entreprise
- 2 Un second facteur hors de la messagerie
- 3 Sessions coupées, appareil nettoyé
- 4 Une alerte sur l'inhabituel
- 5 Les mêmes règles pour les partenaires

Meldis meldis.fr